Security Incident Analysis: Executive Summary

Client: Lumen Soda, Incorporated

Prepared for: Bob , CEO

Prepared by: Maxine Jones, Junior MDR Analyst

January 15,2026

Executive Summary

Bob, the CEO of Lumen Soda, Incorporated, reached out to the MDR team with an urgent request for investigation regarding a potential security incident that involves his daughter's non-corporate computer. Bob raised concern about potential malicious activity on this device may have impacted sensitive files and potential spread to other systems on the network. The MDR team was provided with a Process Monitor (PML) that covers activity on November 28,2016, starting at 11:29 am and ending at 11:51 the same day, approximately 22 minutes of system activity during the incident window. This file reveals a clear chain of infection, and confirmed that there was lateral movement at, at the minimum, one additional machine, as well as impact to remote files.

Malicious Activity Identified

During the investigation, the team identified two malicious executables that created a clear chain of infection o the affected device:

- Gift-card.exe: This file served as the initial dropper that was manually executed by the local administrator account from Explorer.exe from the desktop. This initiated the infection chain and launched the second stage of the malware payload.
- Hwvbgrmymssj.exe: This is the second-stage of the malware that was written into the Windows directory. Once this was activated, it performed network reconnaissance, attempted to gain access across multiple hosts, and was ultimately able to achieve successful lateral movement to a remote machine.

Some of the malicious activity that the MDR team observed includes:

- The execution of the gift-card.exe dropper under administrative privileges, which enabled unrestricted access to the system
- The execution and deployment of hwvbgrmymssj.exe ,the second-stage payload, which helped to initiate broader malicious behavior.
- Authentication to the remote host ADMIN-21139, which then followed with directory traversal and impact to the remote files.
- There were multiple files that can be viewed as ransomware on the remote machine, one example being _ReCoVeRy_+ergfw.*, which an indicate malicious intent and data impact.
- The team also identified access to potentially sensitive user profile directories such as .bash_history, .atom , .azure, and .gitconfig, which can contain tokens, credentials, or even developer secrets.
- Multiple python related files were generated by hwvbgrmymssj.exe within the C:\Python27\Lib\. The high amount of create and write files operations can indicate that the malware used python in the staging and or unpacking environment during the execution phase.
- Lastly, the team noticed that the second stage malware interacted with the Sysinternals metadata files, which includes writing to Eula.txt and psversion.txt. While this behavior isn’t destructive, this behavior suggests that the malware is aware of or reacted to the presence of the administrative or forensic tools that are available on the system.

These behaviors that the team identified collectively demonstrate a complete malicious lifecycle: The initial execution, the payload deployment, environment probing, network scanning, lateral movement, and the remote file impact.

Initial Infection Vector

During the investigation, the team was able to determine that the initial infection vector was through the manual execution of gift-card.exe by the local administrator on the affected machine. When gift-card.exe was launched through Explorer.exe, the executable operated as a dropper, writing and deploying the second-stage payload, which was the hwvbgrmymssj.exe file, into the Windows directory. Due to the user-initiated action, the malware inherited admin level privileges, which enabled it to bypass the usual access restrictions, as well as allowed for the malware to establish the foundation for the subsequent malicious activity that the team observed during the incident window.

Lateral Movement

After the team identified the initial infection vector, the team confirmed that the second-stage malware, hwvbgrmymssj.exe, was able to successfully authenticate to the remote host ADMIN-21139, and that it traversed the file system using the admin user profile. Once the malware is connected, hwvbgrmymssj.exe enumerated several directories that commonly contain sensitive information, which includes .bash_history, .atom, .azure, and even .gitconfig. This indicates that it had access to locations where tokens, credentials, and developer-related data were possibly stored. The team also noticed that multiple ransomware style files were created by the malware on the remote machine, one example being _ReCoVeRy_+ergfw.*. Due to this combination of authenticated access, the traversal of sensitive directories and the remote file modification, the MDR team assessed that the malware was able to achieve a full lateral movement and had a measurable impact on the remote host.

Impact Assessment

The observed activity that the MDR team assessed demonstrated that the malware had a meaningful impact on not only the initial infected machine, but also the remote host that it laterally moved to. The initial system showed that the execution of the dropper gift-card.exe and the subsequent deployment of hwvbgrmymssj.exe, the second –stage payload, granted the malware administrative-level privileges, which allowed it to operate without access level restrictions. With the high volume of Python-related file creation and writing within the C:\Python27\Lib\ directory indicates that the malware leveraged the local environment to stage and unpack the operations during the malware execution process.

However, on the remote host, there was a more significant impact. The malware was able to successfully authenticate to ADMIN-21139, access sensitive user profile directories, as well as create multiple ransomware-style files across several different locations within the admin profile. These actions, along with the repeated creation and writing of ransom artifacts across nested subdirectories confirm that the malware was able to traverse the remote file system and modify the data on the host, which demonstrates a clear compromise on the remote host.

Recommended Next Steps

In order to reduce the likelihood of similar incidents occurring in the future, the MDR team recommends that Bob implements several security measures across not only the affected systems, but the broader environment as well. These steps are intended to not only strengthen the access controls and improve detection capabilities but also limit the impact of user-initiated execution of malware on non-corporate devices, which ensures that both the corporate and personal systems are better protected against similar threats in the future. The MDR team recommends that Bob considers implementing the following actions:

- Fully rebuild or reimage the affected systems in order to ensure that there are no leftover remnants of the malware on either the initially affected system or the remote host

- Reset all the associated passwords, which includes the local administrator's credentials, as well as any accounts used on the compromised device to prevent unauthorized access with the potentially exposed credentials.
- Rotate the API tokens, keys and developer secrets that may have been stored in directories such as the .azure, .gitconfig, .bash_history, or the .atom.
- Remove or restrict the local administrative accounts to ensure that daily operations are performed using the standard user privileges in order to limit the impact of the user-initiated execution
- Deploy endpoint protection or EDR tolling across high-risk and executive devices, this includes those used in home or hybrid environments to improve both the detection and response capabilities.
- Enforce the use of least-privilege access controls so that the elevated permissions are only granted when needed and are monitored appropriately.
- And provide security awareness training for not only the executives but also family members, focusing on identifying suspicious files, downloads and social-engineering attempts.

The implementation of these recommended steps cannot only collectively strengthen the security posture of the organization, but also reduce the risk of similar incidents, and improve the organizations' ability to detect and respond to the malicious activity in the future.